SIMATS ENGINEERING

Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA1405 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. **A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.**

Answer:

No, I would not exploit it. The affected system was never named in the authorization, so touching it beyond observation would fall outside what the client agreed to.

- **Permission first:** Every action in a penetration test must be backed by explicit consent from the asset owner. Silence in the email about this system means no consent for it.
- **Weak scope is a warning sign:** A single-line email leaves targets, timings, and methods undefined. I would pause and ask the client to confirm the scope in writing before going on.
- **Report, don't weaponise:** I would record only what I observed without interacting further, then alert the client promptly so they can fix the issue under responsible disclosure.
- **Do no harm:** Proving impact on an unapproved system could corrupt data, crash services, or expose confidential records, and the client would be the one to suffer.
- **Professional conduct:** I would stay true to honesty, confidentiality, accountability, and respect for the law, which separate a security professional from a criminal intruder.

Conclusion: I would stop at the point of discovery, notify the client, and request a revised written scope. Only after receiving that approval would I validate the finding. Finding a flaw is not the same as being allowed to use it.

2. **You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?**

Answer:

I would not run any injection payload that could read, alter, or delete live customer financial records. Instead I would confirm the flaw in the least risky way available.

- **Pause and evaluate:** I would first judge whether the weakness can be confirmed through code review, error messages, or response behaviour rather than data extraction.
- **Move to a safer copy:** The preferred option is a staging or test replica loaded with masked or synthetic data, where full exploitation poses no privacy risk.
- **Keep the proof minimal:** If live testing is explicitly approved, I would use a harmless, read-only check (for example, showing that a query can be influenced) and stop there.
- **Safeguard the data:** I would never export, store, screenshot, or share actual account details or transactions, and any evidence would be redacted.
- **Work with the client:** A database owner should be on standby, with a recent backup, a rollback plan, and an agreed signal for halting the test.

Precautions that should be taken before the engagement:

1. Sign a contract and written authorization that names the systems in scope.
2. Classify the sensitive assets and flag the production database as high risk.
3. Agree on rules of engagement, including which techniques are banned.
4. Confirm backups, recovery steps, and 24/7 contact details.
5. Set out how data will be handled, stored, destroyed, and how incidents will be reported.
6. Sign a non-disclosure agreement covering any data seen during testing.

Conclusion: A good tester shows that the risk is real while leaving customer money, identity, and privacy untouched.

3. **During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.**

Answer:

I would own the mistake at once and focus on getting the service back up, rather than on defending myself or continuing the work.

How the outage could have been prevented

- **Plan around availability:** Before starting, I should have asked which servers are business-critical and agreed on safe testing windows, such as off-peak hours.
- **Choose gentle techniques:** I should have kept to low-impact scans and avoided brute force, flooding, or load tests unless the client had clearly approved them.

- **Throttle everything:** Slow scan speeds, small thread counts, and short bursts would have given the server room to cope.
- **Watch the target:** Tracking latency, CPU, memory, and error rates would have shown the first signs of strain, so I could stop in time.
- **Prepare an escape route:** A stop word, an on-call contact, and a rollback or restart process should have existed before the first packet was sent.

My responsibilities now

1. Halt all testing right away, including anything running in the background.
2. Inform the client and the emergency contact immediately and honestly.
3. Support the IT team with whatever information helps them restore service.
4. Keep my tool output, commands, and timestamps as evidence for the post-mortem.
5. Identify what caused the failure and write a clear incident report.
6. Suggest fixes, such as rate limiting and better resilience, and agree on safer retesting.

Conclusion: Accidents can happen even to careful testers, but hiding them cannot be excused. Honesty, speed, and accountability protect both the client and the tester's reputation, and testing must not resume until the system is stable and the client agrees.

4. **A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?**

Answer:

This is a legitimate type of exercise, but secrecy raises real dangers because defenders may treat my activity as a genuine attack.

Risks

- **Business disruption:** The IT team might isolate servers, block networks, or restore systems, interrupting real customers and staff.
- **Wasted or misdirected response:** Resources could be pulled into fighting an attack that is not real, and real incidents might be missed at the same time.
- **Legal exposure:** If no senior person approved the test in writing, I could be accused of breaking computer misuse laws, or even reported to the police.
- **Loss of trust:** Staff who feel tricked may lose confidence in management and the security team, and misunderstandings may follow.

How I would structure the engagement

1. Get a signed authorization from a person with real authority, such as the CISO or an executive.
2. Fix the targets, schedule, allowed methods, and a list of forbidden actions.
3. Provide a "get out of jail" letter and contact details I can show if I am stopped.
4. Appoint a trusted white-cell contact who knows about the test and can call it off.
5. Set triggers for stopping, such as a service outage, data exposure, or real attackers appearing.
6. Hold a joint review afterwards, covering what was detected, how fast, and what to improve.

Conclusion: An unannounced test is acceptable only when it is approved, documented, and supervised. The IT staff may be kept in the dark, but the people accountable for the organisation must not be.

5. **You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.**

Answer:

Both services strengthen security, but a vulnerability assessment is about breadth and a red team exercise is about realism and depth.

Scenario: A bank wants both its branches and its online banking platform tested.

Aspect	Red Team Exercise	Vulnerability Assessment
Goal	Check whether the bank can spot and stop a determined attacker	Find, list, and rank as many weaknesses as possible
Method	Goal-based, mimics real attackers and chains weaknesses together	Systematic scanning and checking of assets, mostly automated
Physical	Tests tailgating, badge cloning, and staff awareness within agreed limits	Inspects locks, cameras, alarms, and visitor procedures
Digital	Tries approved attack paths such as phishing and lateral movement	Scans for missing patches, weak settings, and known CVEs
Visibility	Covert; only a few people know it is happening	Open; IT teams know and often assist
Ethics focus	Deception must stay controlled; no harm to staff or customers	Accuracy, privacy, and avoiding service impact
Output	Narrative of the attack path and detection and response gaps	Prioritised vulnerability list with fixes and retest advice

Example: red team exercise

- **Objective:** Approved testers try to reach a mock "crown jewel" file on the bank's internal network.
- **Steps:** They attempt a controlled phishing campaign and a supervised branch entry attempt, using test accounts only.
- **Result:** The bank learns how quickly security staff noticed and how well they responded.

Example: vulnerability assessment

- **Objective:** Authorized scanners review servers, ATMs' network segments, and the web banking portal.
- **Steps:** They log outdated software, weak encryption settings, and possible injection points, and assign severity ratings.
- **Result:** A report lists fixes by priority so the bank can patch and retest.

Rules of engagement (common to both)

1. Written approval from senior management and the owners of every system and site.
2. Defined scope covering named systems, branches, dates, and permitted techniques.
3. No real money movement, no data theft, and no damage to equipment or services.
4. Customer and staff data protected, with any evidence masked and securely stored.
5. A 24/7 emergency contact and a clear procedure for stopping the test.
6. Confidential reporting limited to approved stakeholders, with a handover of all findings.

Conclusion: A vulnerability assessment tells the bank what is weak, while a red team exercise shows whether those weaknesses can be exploited and whether the bank would notice. Each needs authorization, confidentiality, and care for customers.

Code of Conduct:

I ___N. Madhusudhan (192425303)___ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem

		requirements and operations			
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand